

Warsaw, November 26, 2024

Decision

DKN.5131.6.2024

Based on Article 104 § 1 of the Act of June 14, 1960, the Code of Administrative Procedure (Journal of Laws of 2024, item 572) in connection with Articles 7, 60, 101, and 103 of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781) and Article 57(1)(a) and (h), Article 58(2)(e) and (i), Article 83(1) and (2), Article 83(4)(a) in connection with Article 33(1) and Article 34(1), (2), and (4) of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 05.04.2016, p. 1, OJ EU L 127 of 23.05.2018, p. 2, and OJ EU L 74 of 04.03.2021, p. 35), hereinafter referred to as Regulation 2016/679, after conducting an ex officio administrative proceeding regarding the violation of personal data protection regulations by X. ul. (...), President of the Personal Data Protection Office,

1. Finds that X. ul. (...) violated the provisions:

- a) Article 33(1) of Regulation 2016/679, consisting of failing to notify the President of the Personal Data Protection Office of a personal data breach without undue delay, and no later than 72 hours after becoming aware of the breach;
- b) Article 34(1) and (2) of Regulation 2016/679, consisting of failing to inform the data subject without undue delay about the personal data breach and not providing that person, within the notification directed to them, with an adequate description of the measures taken or proposed by the controller to address the personal data breach, including measures to mitigate its potential negative effects,

2. Imposes on X. ul. (...) an administrative fine in the amount of 29,684.04 PLN (in words: twenty-nine thousand six hundred eighty-four zlotys and four groszy),

3. Orders X. ul. (...) to notify – within 3 days from the date of delivery of this decision – the person whose data was disclosed in connection with the transfer of their medical documentation to an unauthorized person, about the personal data breach in order to provide them with the information required under Article 34(2) in connection with Article 33(3)(d) of Regulation 2016/679, i.e., a description of the measures taken or proposed by the controller to address the breach – including measures to mitigate its potential negative effects.

Justification

To the President of the Personal Data Protection Office, hereinafter also referred to as "the President of UODO" or "the supervisory authority," on November 7, 2022, information was received from (...) regarding the possibility of a personal data breach at X. ul. (...), hereinafter also referred to as "the Hospital" or "the Controller." From the aforementioned letter and its attachments, it was evident that the medical documentation in the form of the Preoperative Anesthesiology Questionnaire issued to a patient in the obstetrics and gynecology department, along with her medical documentation, contained personal data, namely the first name, last name, date of birth, PESEL number, and health data of another patient of the Controller. The President of UODO conducted an explanatory proceeding regarding the possibility of a personal data breach at the Hospital (registered under reference number (...)), and then on March 5, 2024, initiated an ex officio administrative proceeding regarding the breach by the Hospital, as the data controller, of the obligations arising from the provisions of Article 33(1) and Article 34(1) and (2) of Regulation 2016/679. The President of UODO, as a result of the conducted explanatory proceeding and administrative proceeding, established the following factual state.

I. The President of UODO, upon receiving information about the possibility of a personal data breach at the Hospital, in letters dated November 15 and 25, 2022, requested the Controller to clarify whether, in connection with the erroneous issuance of the document in the form of the Preoperative Anesthesiology Questionnaire to an unauthorized person, an analysis was conducted regarding the risk of violation of the rights or freedoms of natural persons necessary to assess whether there was a personal data breach requiring notification to the President of UODO and the data subject.

II. In response to the President of UODO's request, the Controller, in a letter dated December 5, 2022, indicated that due to the lack of notification of the error at the time of issuing the documentation, it was not possible to unequivocally identify the incident. Furthermore, it was indicated that the (...) Department was tasked with checking the medical history of the data subject for irregularities in the issuance of the documentation; however, it was found that all documents were compliant with the standard and contained the correct anesthesiology questionnaire. In the aforementioned letter, the Controller also indicated that they notified the data subject about the breach of her personal data and implemented remedial measures by having a conversation with the head of the department and medical staff, as well as establishing a training date for "Procedures in the Event of Breach and Protection of Personal Data."

III. On February 14, 2023, the President of UODO directed to Administrator's letter, in which he called upon him to present the results of the risk analysis, based on which it was determined that there was no high risk of violation of the rights or freedoms of natural persons and the content of the information provided to the person to whom the data pertains. In a letter dated February 24, 2023, the Hospital provided information regarding the conducted risk analysis and presented the content of the notification directed to the person whose data is concerned.

IV. The Administrator reported the personal data breach only upon receiving notification from the President of the Personal Data Protection Office (UODO) about the initiation of proceedings, i.e., on March 27, 2024, thus failing to meet the 72-hour deadline for reporting the personal data breach. As part of the aforementioned notification, the Hospital provided, among other things, information that it had notified the person whose data is concerned about the data breach and attached the content of that notification. The notification did not contain the information required under Article 34(2) in conjunction with Article 33(3)(d) of Regulation 2016/679, i.e., a description of the measures taken or proposed by the administrator to address the breach – including measures to minimize its potential negative effects.

In this factual state, after reviewing all the evidence gathered in the case, the President of the Personal Data Protection Office considered the following:

I. Violation of Article 33(1) and Article 34(1) and (2) of Regulation 2016/679. According to Article 4(12) of Regulation 2016/679, a personal data breach is a security breach leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure, or unauthorized access to personal data transmitted, stored, or otherwise processed. Article 33(1) and (3) of Regulation 2016/679 states that in the event of a personal data breach, the administrator shall notify the supervisory authority competent under Article 55 without undue delay – where feasible, no later than 72 hours after becoming aware of the breach – unless it is unlikely that the breach will result in a risk to the rights or freedoms of natural persons. A notification submitted to the supervisory authority after the 72-hour period must include an explanation of the reasons for the delay. The notification referred to in paragraph 1 must at least: a) describe the nature of the personal data breach, including, where possible, the categories and approximate number of data subjects concerned, as well as the categories and approximate number of personal data records concerned by the breach; b) contain the name and contact details of the data protection officer or another contact point from which more information can be obtained; c) describe the likely consequences of the personal data breach; d) describe the measures taken or proposed by the administrator to address the personal data breach, including, where appropriate, measures to mitigate its potential negative effects.

Furthermore, based on Article 34(1) of Regulation 2016/679, in situations where there is a high risk of violation of the rights or freedoms of natural persons, the administrator is obliged to notify the data subject of the breach without undue delay. Article 34(2) of the Regulation states that a proper notification should: 1) describe the nature of the personal data breach in clear and plain language; 2) contain at least the information and measures referred to in Article 33(3)(b), (c), and (d) of Regulation 2016/679, i.e.: a) the name and contact details of the data protection officer or another contact point from which more information can be obtained; b) a description of the likely consequences of the

personal data breach; c) a description of the measures taken or proposed by the administrator to address the personal data breach, including, where appropriate, measures to mitigate its potential negative effects.

The analysis of the above provisions indicates that depending on the level of risk of violation of the rights or freedoms of natural persons that the administrator is dealing with, his obligations towards the supervisory authority and the data subjects differ. If, as a result of the risk analysis, the administrator determines that the likelihood of a risk to the rights or freedoms of natural persons is low, he is not obliged to report the breach to the President of the Personal Data Protection Office. The indicated breach must only be recorded in the internal register of breaches. In the case of identifying a risk to the rights or freedoms of natural persons, the administrator is obliged to report the personal data breach to the President of the UODO, as well as to make an entry in the internal register of breaches. The occurrence of a high risk to the rights or freedoms of natural persons, in addition to an entry in the register of breaches, requires the administrator to take appropriate actions both towards the supervisory authority (reporting the personal data breach) and also towards the data subjects. Therefore, in the case of personal data breaches that may pose a high risk to the rights or freedoms of natural persons, Regulation 2016/679 introduces an additional obligation for the administrator to promptly notify the data subject unless the administrator has taken preventive measures before the breach occurred or remedial actions after the breach occurred (Article 34(3) of Regulation 2016/679).

From the above considerations, it follows that in the event of the administrator detecting a personal data breach, it is essential first to conduct an analysis regarding the occurrence of risk. violations of the rights or freedoms of natural persons. The administrator is exempt from the obligation to notify the supervisory authority of a breach if the conducted analysis shows that there is at most a small probability of a risk to the rights or freedoms of natural persons. However, it should be noted that the supervisory authority may request the administrator to justify the decision not to report the breach; therefore, the conclusions from the conducted analysis should be recorded in the internal record of breaches. It is worth noting that in the Guidelines of the European Data Protection Board (EDPB) No. 9/2022[1] adopted on March 28, 2023, hereinafter referred to as Guidelines 9/2022, there are recommendations regarding the reporting of personal data breaches to the supervisory authority.

In Guidelines 9/2022, the EDPB indicates the factors to be considered when assessing risk, referring to recitals 75 and 76 of Regulation 2016/679, which suggest that the administrator should take into account both the likelihood of occurrence and the severity of the threat to the rights or freedoms of the data subject. In the event of a personal data breach, the administrator should focus on the risk of impact on the individual arising from the breach. Therefore, when assessing the risk to the individual resulting from the personal data breach, the administrator should consider the specific circumstances of the breach, including the severity of the potential impact and the likelihood of its occurrence. In this regard, when assessing risk, the EDPB recommends considering criteria such as: the type of breach, the nature, sensitivity, and amount of personal data, as well as the ease of identification, as these may affect the level of risk to individuals. The risk of violation of the rights or freedoms of a natural person, according to Guidelines 9/2022, will be greater when the consequences of the breach are more serious, as well as when the likelihood of their occurrence increases. The guidelines indicate that in case of any doubts, the administrator should report the breach, even if such caution may seem excessive.

It should be emphasized that the assessment of the risk of violation of the rights or freedoms of a natural person should be made from the perspective of the affected individual, not the interests of the administrator. This is particularly important because based on the notification of a personal data breach, the individual can assess whether, in their opinion, the security incident may have negative consequences for them and take appropriate remedial actions. Also, based on the information provided by the administrator regarding the nature of the breach and the measures taken or proposed to remedy the breach, the individual can assess whether, after the breach occurred, the data administrator still provides assurance of proper processing of their personal data in a manner that ensures their security. The lack of notification of a personal data breach to the individual in the case of

a high risk of violation of their rights or freedoms deprives them not only of the opportunity to respond appropriately to the breach but also of the ability to independently assess the breach, which concerns their personal data and may have serious consequences for them. On the other hand, the lack of reporting a personal data breach deprives the supervisory authority of the ability to respond appropriately to the breach, which involves not only assessing the risk of violation of the rights or freedoms of the individual but also, in particular, verifying whether the administrator has taken appropriate measures to remedy the breach and minimize the negative effects for the individuals concerned, as well as whether appropriate security measures have been implemented to minimize the risk of recurrence of the breach.

Reporting personal data breaches by administrators thus constitutes an effective tool contributing to a real improvement in the security of personal data processing. By reporting a breach to the supervisory authority, administrators inform the President of the Personal Data Protection Office (UODO) whether, in their opinion, there is a high risk of violation of the rights or freedoms of the individuals whose data are affected, and – if such a risk exists – whether they have provided appropriate information to the individuals affected by the breach. In justified cases, they may also provide information that notification, in their opinion, is not necessary due to the fulfillment of the conditions specified in Article 34(3)(a) and (b) of Regulation 2016/679. The President of the UODO verifies the assessment made by the administrator and may – if the administrator has not notified the individuals concerned – request such notification. Reporting personal data breaches allows the supervisory authority to respond appropriately, which can mitigate the effects of such breaches, as the administrator is obliged to take effective actions to protect individuals and their personal data, which on one hand allows for the monitoring of the effectiveness of existing solutions, and on the other hand, for the assessment of modifications and improvements aimed at preventing irregularities similar to those covered by the breach. Meanwhile, notifying individuals about the breach provides the opportunity to convey information to these individuals about the risks associated with the breach and to indicate actions that they can take to protect themselves from potential negative consequences of the breach (this enables the individual to make an independent assessment of the breach in the context of the possibility of materializing negative consequences for such an individual and to decide whether to take or refrain from taking remedial actions).

As follows from the above considerations, the administrator should immediately upon obtaining information about the breach...

data protection, is obliged to conduct a risk assessment related to this breach, concerning the rights or freedoms of the individuals affected by the breach. The risk assessment should serve as the basis for the administrator's decision leading to further actions aimed at fulfilling the obligations arising from Article 33(1) and Article 34(1) and (2) of Regulation 2016/679. In this case, the Administrator, when providing the risk assessment regarding the infringement of the rights or freedoms of individuals in connection with the data protection breach, indicated that, in his opinion, the risk of inconvenience related to the disclosure of the patient's personal data to an unauthorized person is low, and its existence does not require further action. The basis for accepting such a level of risk included, among other things, the fact that “[...] the indicated consequences in the context of the realization of the analyzed risk did not occur and will not occur.” Furthermore, in a letter dated January 12, 2023, the Administrator stated that “In the situation where we would have known about the incident in 2021, i.e., during the stay of both ladies in one room, the possibility of proving to the medical staff a mistake regarding the anesthesiology questionnaires would have been much greater, and thus the risk assessment would have been medium.”

The hospital did inform the person whose data was affected about the data protection breach by providing her with the content of the notification; however, due to the failure to make the appropriate notification of the data protection breach to the President of the UODO within the legally prescribed time frame (72 hours from the discovery of the breach), it deprived the supervisory authority of the opportunity to take appropriate action regarding this breach, and consequently the ability to conduct a proper analysis of the content of the notification sent to this person, in terms of fulfilling the

Administrator's obligations arising from Article 34(2) in connection with Article 33(3) of Regulation 2016/679 and providing the aforementioned person with complete information regarding the possible consequences of the breach, as well as the measures that this person can take to protect herself from the potential effects of the breach.

It should be remembered that the accidental disclosure of personal data to even one identified person can lead to an increase in the scale of the breach and thus create a risk of violation of the rights or freedoms of the individual whose data is concerned. In the context of the aforementioned risk assessment criteria proposed by the EROD in Guidelines 9/2022, i.e., the type of breach, the nature, sensitivity, and amount of personal data, as well as the ease of identification, the risk assessment presented by the administrator was not supported by any considerations regarding the weight of the possible consequences of the breach. The Administrator did not take into account, for instance, that among the categories of breached personal data were health-related data, which are classified as special categories of personal data and as such should be subject to special protection by the administrators. Consequently, the disclosure of personal data belonging to this category carries a high risk of violating the rights or freedoms of the individuals concerned.

It should also be emphasized that information about health status, along with the other personal data disclosed to an unauthorized person, i.e., first name, last name, date of birth, and PESEL identification number, undoubtedly allows for the identification of the individual whose data is concerned, especially considering the fact that, as the Administrator emphasized, both ladies were placed in one room. Furthermore, the collected evidence indicates that the patient's personal data may still be in the possession of an unauthorized person. This means that the risk of violation of the rights or freedoms of the patient has not been eliminated. As indicated by the Provincial Administrative Court in Warsaw in its judgment of January 21, 2022, case file II SA/Wa 1353/21, "(...) there is no certainty that before these actions, this person did not make, for example, a photocopy or did not record the personal data contained in the document in another way, e.g., by writing them down." Therefore, it is difficult for the President of the UODO to understand the above-mentioned statement of the Administrator, where he indicates that if he had known about the data protection breach earlier, the risk associated with it would have been higher, while the Administrator, until the notification of the data protection breach to the supervisory authority, did not take any actions aimed at minimizing the risk of violation of the rights or freedoms of the individual whose data is concerned, including not properly notifying this person about the possible consequences of this breach and not indicating the possible measures that this person can take to secure her data against unauthorized use.

As indicated in Guidelines 9/2022, a data protection breach can potentially lead to a range of negative consequences for individuals whose data is the subject of the breach. Among the possible consequences of the breach, the EROD lists: physical harm, material or non-material damages. Examples of such damages include, among others: discrimination, identity theft or identity fraud, financial losses, damage to reputation, breach of confidentiality of personal data, and significant economic or social harm. In this case, there is no doubt that due to the scope of the data covered by the data protection breach, including the PESEL identification number along with the first name and last name and health-related data, there is a high probability of the occurrence of the aforementioned damages.

It should also be emphasized that despite the time separating the occurrence of the data protection breach from the Hospital's acquisition of information about the event, the risk of violation of the rights or freedoms of the individual whose data is concerned cannot be mitigated by the fact that...

At present, the Administrator is not aware of the materialization of possible negative consequences of a breach of personal data protection. In the risk analysis dated December 29, 2022, presented in the letter of February 24, 2023, the administrator assessed the risk as "within the norm." Furthermore, as previously indicated, he noted that "the indicated effects in the context of the materialization of the analyzed threat did not occur and will not occur." In this regard, it is important to emphasize that negative consequences related to a breach of personal data protection do not need to materialize for the administrator to have an obligation to report the breach of personal data protection and to notify the

data subject. This means that the Administrator cannot condition the fulfillment of obligations arising from Article 33(1) and Article 34(1) of Regulation 2016/679 on the occurrence of harm to the individuals whose personal data is affected by the breach. As stated by the Administrative Court in Warsaw in its judgment of September 22, 2021, in case file II SA/Wa 791/21: "It should be emphasized that the possible consequences of the event do not need to materialize. The content of Article 33(1) of Regulation 2016/679 indicates that the mere occurrence of a breach of personal data protection, which is associated with a risk of infringement of the rights or freedoms of individuals, implies an obligation to report the breach to the relevant supervisory authority, unless it is unlikely that the breach will result in a risk to the rights or freedoms of individuals" (the Court similarly ruled in judgments of July 1, 2022, case file II SA/Wa 4143/21, August 31, 2022, case file II SA/Wa 2993/21, November 15, 2022, case file II SA/Wa 546/22, and April 26, 2023, case file II SA/Wa 1272/22).

As indicated in Guidelines 9/2022, when the administrator becomes aware of a breach that is subject to the obligation to report, it must be reported without undue delay, and no later than within 72 hours. Furthermore, the same guidelines indicate that in case of doubt, the Administrator should, out of an abundance of caution, notify the supervisory authority of the breach of personal data protection. Therefore, it follows that since the Administrator decided to notify the data subject of the breach of their personal data protection, anticipating that this breach may involve a high risk to the rights or freedoms of individuals, he was undoubtedly also obliged to report the breach of personal data protection to the President of the UODO, which he only did after the President of the UODO initiated administrative proceedings in the matter. As follows from Article 33(1) of Regulation 2016/679, in the case of a breach of personal data protection, the administrator must report it to the supervisory authority without undue delay, unless it is unlikely that the breach will result in a risk to the rights or freedoms of individuals.

In the context of the above explanations, the Hospital seems to forget that when applying the provisions of Regulation 2016/679, the purpose of this regulation (expressed in Article 1(2)), which is to protect the fundamental rights and freedoms of individuals, particularly their right to personal data protection, must be taken into account. Moreover, the protection of individuals in relation to the processing of personal data is one of the fundamental rights (first sentence of Recital 1 of the preamble). In case of any doubts, for example, regarding the fulfillment of obligations by administrators – including in situations where there has been a breach of personal data protection – these values should be considered first.

The supervisory authority's obtaining of complete information required by Article 33(3) of Regulation 2016/679 about a specific breach of personal data protection allows it to properly assess such a breach and respond appropriately, for example, by demanding that the administrator notify the data subjects when necessary, and the administrator has not done so on his own initiative. A lack of appropriate and timely response to breaches of personal data protection increases the risk of the materialization of associated damages.

It is worth emphasizing that when assessing the risk of infringement of the rights or freedoms of individuals, which is among the factors determining the reporting of a breach of personal data protection, both the probability factor and the weight of potential negative consequences must be considered together. A high level of either of these factors affects the overall assessment, which determines the fulfillment of the obligation specified in Article 33(1) of Regulation 2016/679. Given that due to the scope of the disclosed personal data in the analyzed case, there was a possibility of serious negative consequences materializing for the data subject (as demonstrated above), the weight of the potential impact on the rights or freedoms of the individual should be regarded as high. At the same time, the probability of a high risk arising from the breach in question is not small and has not been eliminated. Thus, it must be stated that in connection with the breach in question, there was a high risk of infringement of the rights or freedoms of the individual whose data is concerned, which consequently determines the obligation to report the breach of personal data protection to the supervisory authority.

The Hospital has received several notifications from the supervisory authority indicating that medical

documentation containing personal data regarding the first name, last name, date of birth, PESEL number, and health-related data has come into the possession of another patient of the Administrator. The first notification regarding the possible occurrence of a breach of personal data protection was received by the Hospital along with a letter from the President of the UODO dated November 15, 2022. At that time, the Administrator indicated...

due to receiving too little information allowing for the identification of the event. In this regard, additional information regarding the event was provided to the Administrator. Nevertheless, in a letter dated December 5, 2022, the Administrator informed that it was still not possible for him to detect the event; however, he indicated that he had informed the data subject about the breach of her personal data protection.

The Administrator's actions indicate inconsistency, as on one hand, he informed the supervisory authority about the inability to identify the event, which prevented him from reporting the breach of personal data protection, while on the other hand, he decided to notify the data subject about the breach of her personal data protection, providing her with certain information regarding the occurrence of the breach of personal data protection.

On December 19, 2022, the President of the Personal Data Protection Office (UODO) provided the Administrator with an anesthesiology questionnaire that had been issued to an unauthorized person, which was attached to the correspondence initiating the explanatory proceedings. Even then, the Administrator did not decide to report the breach of personal data protection to the supervisory authority, justifying his position with an analysis of the event conducted. The presented analysis indicated that theoretically, there could have been a breach of personal data protection; however, the possibility of proving the occurrence of an event resulting in a breach of personal data protection was low, and the data subject might face significant inconveniences that are manageable. According to the Administrator, as of the date of submitting explanations (i.e., January 12, 2023), the risk of infringement of the rights or freedoms of natural persons was low, due to the fact that the event occurred over a year earlier, and the threat had not materialized in the past. However, this cannot be agreed upon. Based on the information provided to the Administrator by the supervisory authority, he had full capability to determine what had happened, including the ability to identify the person whose data had been disclosed to an unauthorized person. Consequently, he had sufficient information to ascertain the occurrence of a breach of personal data protection, assess the level of risk of infringement of the rights or freedoms of that person, and properly fulfill his obligations under Article 33(1) and Article 34(1) and (2) of Regulation 2016/679.

Meanwhile, only after receiving notification of the initiation of administrative proceedings in the matter, i.e., after 16 months from the moment all information allowing the Hospital to ascertain the breach of personal data protection was provided, did the Administrator decide to fulfill his obligation to report the breach of personal data protection to the supervisory authority. Thus, the Administrator significantly exceeded the deadline set out in Article 33(1) of Regulation 2016/679 for compliance (72 hours from the detection). During this time, the factual situation presented to the Administrator in the aforementioned letters from the authority did not change. In the breach notification form dated March 27, 2024, the Administrator indicated, however, that he had conducted a new risk analysis, which revealed the existence of a high risk of infringement of the rights or freedoms of natural persons. Moreover, in the aforementioned form, in point 3A, the Hospital stated that it had identified the breach of personal data protection on November 24, 2022, i.e., less than a week after receiving the letter from the President of UODO on this matter dated November 18, 2022.

Therefore, the position of the Hospital expressed in the letter dated February 24, 2023, that "If the situation were to occur now and the Inspector for Personal Data Protection and the Administrator of the entity were to be immediately notified, the risk assessment would have been calculated completely differently. We assume that the President of the Personal Data Protection Office would have been immediately notified and the risk would have been assessed as unacceptable, as we could not predict what would happen to the personal and medical data that would have been improperly accessed by unauthorized persons for processing personal and medical data," is unacceptable, since after 16

months from the identification of the breach of personal data protection, the Administrator, in the new risk analysis, states the occurrence of a high risk of infringement of the rights or freedoms of natural persons and notifies the President of UODO about the event. This indicates a lack of consistency on the part of the Administrator regarding the actions taken concerning personal data protection and an inconsistent assessment of similar events, which de facto lead to the same consequences for the data subject.

At the same time, it is surprising that despite the initial lack of determination of risk resulting in the necessity to notify the supervisory authority about the breach of personal data protection, the Administrator decided to notify the data subject and implement remedial measures to prevent the recurrence of such a breach in the future. The above indicates a conscious failure to report the breach of personal data protection to the supervisory authority, in which there was a high risk of infringement of the rights or freedoms of the natural person.

In summary, it should be stated that in the present case, there is a high risk of infringement of the rights or freedoms of the person affected by the breach of personal data protection, which in turn resulted in the Hospital's obligation to report the breach of personal data protection to the supervisory authority within 72 hours of its detection, in accordance with Article 33(1) of Regulation 2016/679, as well as to notify that person about the breach of her personal data protection, in accordance with Article 34(1) of Regulation 2016/679, which must include all information specified in Article 34(2) of Regulation 2016/679. It should also be stated that in the present case...

there are no grounds to state that the Administrator was, for any reason, exempt from the obligation to report a personal data breach to the supervisory authority within the timeframe specified in Article 33(1) of Regulation 2016/679 and the obligation to notify the affected individual (in accordance with Article 34(1) of that regulation). In the circumstances of the case under review, it cannot reasonably be argued that it is unlikely that the breach would result in a risk to the rights or freedoms of the individual whose data is concerned. The personal data breach involved, it should be emphasized again, data concerning: first name, last name, PESEL identification number, and health data, which were disclosed to an unauthorized person. In the opinion of the supervisory authority, there is therefore no justification for the Hospital's failure to fulfill the obligation arising from Article 33(1) of Regulation 2016/679 within the timeframe set out in that provision. In the circumstances presented, such a significant delay in reporting the personal data breach to the supervisory authority is therefore unacceptable.

In a situation where a personal data breach presents a high risk to the rights or freedoms of natural persons, the administrator is obliged to implement all appropriate technical and organizational measures to immediately ascertain the occurrence of the personal data breach and to promptly inform the supervisory authority as well as the individuals concerned. The administrator should fulfill this obligation as quickly as possible.

On January 12, 2023, the Administrator informed the supervisory authority about the notification to the affected individual, and then, by letter dated February 24, 2023, provided the content of that notification (date of notification to the aforementioned individual: February 24, 2023). The notification referred to a prior telephone conversation between the Administrator and that individual, in which the Hospital's Data Protection Officer informed the individual about the occurrence of a breach of their personal data. In the content of the notification, the Administrator assured the individual that the risk of infringement of their rights or freedoms was low, and that the threat of unpleasantness related to the breach of personal data would not occur or that the possibility of its occurrence was negligible. Furthermore, the Administrator provided the aforementioned individual with a description of the actions taken by the Hospital in connection with the personal data breach, without indicating any possible consequences of the breach of their personal data for that individual, as well as the remedial measures that the individual could take to minimize the effects of the data breach.

Subsequently, along with the notification of the personal data breach made on March 27, 2024 (in which the Hospital indicated that the aforementioned breach was identified on November 24, 2022), the Administrator again provided the individual concerned with information regarding the breach of their personal data. However, the content of the notification provided to the data subject does not

contain all the information required pursuant to Article 34(2) in conjunction with Article 33(3) of Regulation 2016/679, i.e., a description of the measures taken or proposed by the administrator to remedy the breach - including, where appropriate, measures to minimize its negative effects, taking into account all categories of personal data breached, i.e., health data.

It should therefore be emphasized again that health data, in accordance with Regulation 2016/679, belongs to special categories of personal data and as such is subject to specific processing principles and should be afforded special protection by its administrators. In the event of a personal data breach, it creates a high risk of infringement of the rights or freedoms of a natural person, which obliges the administrator to notify such an individual about the consequences that may arise in connection with the breach of this category of data and the measures that they can take to minimize the negative effects of the breach. The lack of indication of actions that such an individual can take independently to remedy the breach and minimize its potential effects, concerning all data disclosed to an unauthorized person as a result of the personal data breach, may hinder the data subject's ability to make an informed decision regarding the proper safeguarding of their data against unauthorized use. The EDPB in the aforementioned guidelines indicates that the main purpose of notifying individuals is to provide specific information about the steps they should take to protect themselves from the negative consequences of the breach of their personal data. It should be emphasized that the measures proposed to the individual concerned to remedy the breach, including measures to minimize its negative effects, should correlate with the possible negative consequences of the personal data breach presented to that individual. Therefore, it is not sufficient to indicate in the content of the notification of the personal data breach that "the Hospital should be informed immediately upon obtaining information about the unauthorized use of your data," as this prevents the data subject from effectively preventing the negative consequences of the breach of health data, in connection with the effect indicated by the Hospital in the form of discrimination against that individual. Thus, the Administrator did not provide the individual concerned with all the required information, in accordance with Article 34(2) in conjunction with Article 33(3)(d) of Regulation 2016/679.

Regardless of the above, it should be emphasized that

****Notification of the Data Subject Regarding the Breach of Personal Data Protection****

Pursuant to Article 34(1) of Regulation 2016/679, the notification to the data subject about the breach of their personal data protection should occur without delay. It is difficult to accept that the notifications were provided to the aforementioned person (albeit incomplete) on February 24, 2023, and subsequently on March 27, 2024, occurred without delay, given that the incident took place in 2021, and the first information allowing for the determination of the breach of personal data protection was received by the Hospital from the President of the UODO in a letter dated November 15, 2022. This consequently indicates a violation by the Administrator of the aforementioned provision of Regulation 2016/679.

In applying the provisions of Regulation 2016/679, one must consider the purpose of this regulation (expressed in Article 1(2)), which is to protect the fundamental rights and freedoms of natural persons, particularly their right to the protection of personal data. Furthermore, the protection of natural persons in relation to the processing of personal data is one of the fundamental rights (first sentence of Recital 1 of the preamble). In the case of any doubts, for example, regarding the fulfillment of obligations by administrators - including in situations where a breach of personal data protection has occurred - these values should be taken into account first.

Article 34(1) and (2) of Regulation 2016/679 aims not only to ensure the most effective protection of the fundamental rights or freedoms of data subjects but also to implement the principle of transparency, which arises from Article 5(1)(a) of Regulation 2016/679 (see Witold Chomiczewski [in:] GDPR. General Data Protection Regulation. Commentary, ed. E. Bielak – Jomaa, D. Lubasz, Warsaw 2018). Proper fulfillment of the obligation specified in Article 34 of Regulation 2016/679 is intended to provide data subjects with quick and clear information about the breach of their personal data protection, along with a description of the possible consequences of the breach of personal data protection and the measures they can take to minimize its potential negative effects. By acting in

accordance with the law and demonstrating care for the interests of the data subjects, the administrator should have ensured, without unnecessary delay, the possibility for the data subject to achieve the best possible protection of their personal data. To achieve this goal, it is essential at least to indicate the information listed in Article 34(2) of Regulation 2016/679, which the administrator failed to fulfill. Therefore, by deciding not to report the breach of personal data protection to the supervisory authority within the timeframe specified in Article 33(1) of Regulation 2016/679, as well as failing to notify the data subject without unnecessary delay and subsequently not providing them with all the required information, the administrator effectively deprived that person of reliable information about the breach of personal data protection and the opportunity to counteract potential damages.

Consequently, it should be stated that the Administrator did not report the breach of personal data protection to the supervisory authority within the timeframe specified in Article 33(1) of Regulation 2016/679, i.e., within 72 hours of becoming aware of the breach of personal data protection, and did not promptly notify the data subject in a proper manner about the breach of their personal data protection, in accordance with Article 34(1) and (2) of Regulation 2016/679, which constitutes a violation of these provisions by the Administrator.

According to Article 34(4) of Regulation 2016/679, if the administrator has not yet notified the data subject about the breach of personal data protection, the supervisory authority - taking into account the likelihood that this breach of personal data protection will result in a high risk - may require the administrator to do so or may determine that one of the conditions referred to in paragraph 3 has been met. Therefore, the President of the UODO, acting on the basis of Article 58(2)(e) of Regulation 2016/679, ordered the Administrator to notify the person affected by the breach of personal data protection within the scope and timeframe specified in the operative part of this decision.

****II. Justification for Imposing and Determining the Amount of the Administrative Fine****

Considering the above findings and the established violations of the provisions of Regulation 2016/679, the President of the UODO, exercising the authority granted to him under Article 58(2)(i) of Regulation 2016/679, according to which each supervisory authority has the power to impose, in addition to or instead of other corrective measures provided for in Article 58(2)(a)-(h) and (j) of this regulation, an administrative fine pursuant to Article 83(4)(a) and (5)(a) of Regulation 2016/679, having regard to the circumstances established in the proceedings, determined that there were grounds for imposing an administrative fine on the Administrator.

According to Article 83(4)(a) of Regulation 2016/679, violations of the provisions concerning the obligations of the administrator and the processor, referred to in Articles 8, 11, 25-39, and 42 and 43, are subject, according to paragraph 2, to an administrative fine of up to EUR 10,000,000, or in the case of an enterprise, up to 2% of its total annual worldwide turnover from the previous financial year, with the higher amount applying.

In this case, the administrative fine imposed on the Administrator was for the violation of Article 33(1) and Article 34(1) and (2) of Regulation 2016/679 based on the aforementioned Article 83(4)(a) of Regulation 2016/679.

In deciding to impose an administrative fine, the President of the UODO - in accordance with the provisions of Article 83(2)(a)-(k) of Regulation 2016/679 - took into account the following circumstances of the case, which necessitate the application of this type of sanction in this case and which have a burdening effect on the amount.

****Imposed Administrative Monetary Penalty:****

1. The nature, gravity, and duration of the violation, taking into account the nature, scope, or purpose of the processing in question, the number of affected individuals whose data is concerned, and the extent of the damage suffered by them (Article 83(2)(a) of Regulation 2016/679). In this case, a violation of Article 33(1) of Regulation 2016/679 was identified (consisting of the failure to notify the President of the Personal Data Protection Office of the personal data breach without undue delay, and no later than 72 hours after becoming aware of the breach) as well as Articles 34(1) and (2) of

Regulation 2016/679 (consisting of the failure to provide the affected individual, within the notification directed to them, with an adequate description of the measures taken or proposed by the controller to address the personal data breach, including measures to minimize its potential negative effects). These violations are related to an incident involving the disclosure of personal data of one patient of the Hospital in the form of their first name, last name, PESEL identification number, and health-related data as a result of providing the Anesthesia Survey Card to an unauthorized person. This incident is of significant weight and serious nature, as it may lead to material or non-material damages for the individual whose data has been breached, and the likelihood of such damages occurring is high.

It should also be emphasized that the unauthorized disclosure of the Anesthesia Survey Card of the Hospital patient involved the unlawful disclosure of information covered by medical confidentiality, which further increases the severity of the breach and indicates the possibility of negative consequences for the individual whose data is concerned. Although there is no evidence in this case that the individual whose data was accessed by the unauthorized person suffered material damage, the mere breach of confidentiality of their data constitutes non-material damage (harm) for them. An individual whose data has been unlawfully obtained may at least experience fear of losing control over their data, identity theft, or identity fraud, discrimination, or ultimately financial loss. As indicated by the District Court in Warsaw in its judgment of August 6, 2020, case file no. XXV C 2596/19, fear, and thus loss of security constitutes a real non-material damage associated with the obligation to remedy it. Furthermore, the Court of Justice of the EU in its ruling of December 14, 2023, in the case of *Natsionalna agentsia za prihodite (C-340/21)* emphasized that "Article 82(1) of the GDPR should be interpreted in such a way that the fear of potential misuse of personal data by third parties, which the data subject experiences as a result of a breach of this regulation, may in itself constitute 'non-material damage' within the meaning of this provision."

The President of the Personal Data Protection Office also considers the long duration of the breach of the provisions of Regulation 2016/679 by the Hospital as an aggravating circumstance. It should be assumed that the violation of the aforementioned provisions of Regulation 2016/679 began on November 18, 2022 (i.e., at the moment when the Hospital received correspondence addressed to it by the President of the Personal Data Protection Office, thereby obtaining information about the occurrence of a personal data breach). The violation of Article 33(1) of Regulation 2016/679 ended on March 27, 2024, with the submission of the personal data breach notification to the supervisory authority. However, the violation of Articles 34(1) and (2) of Regulation 2016/679 continues, as the individual affected by the personal data breach has still not received complete and accurate information regarding this breach.

In this case, the violation of the provisions of Regulation 2016/679 concerned the personal data of only one individual. This number of affected individuals, especially given the fact that the Hospital – due to the scale and scope of its activities – processes the personal data of a very large number of individuals, should be considered small, which is in favor of the Controller; however, this did not change the overall assessment, i.e., the recognition in the analyzed case of the criterion from Article 83(2)(a) of Regulation 2016/679 as aggravating.

2. The intentional nature of the violation (Article 83(2)(b) of Regulation 2016/679). According to the Guidelines of the Article 29 Working Party on the application and determination of administrative monetary penalties for the purposes of Regulation No. 2016/679 (hereinafter referred to as the WP253 Guidelines), confirmed by the Guidelines 04/2022 on calculating administrative monetary penalties based on the GDPR (hereinafter referred to as the 04/2022 Guidelines), intent "includes both knowledge and deliberate action, in relation to the characteristics of the prohibited act." The Controller made a conscious decision, supported by a risk analysis dated December 29, 2022, not to notify the President of the Personal Data Protection Office of the personal data breach within 72 hours of its discovery and not to notify the affected individual without undue delay. It is undisputed that the Controller, processing personal data of a special category, namely health data, should have knowledge in the field of personal data protection, including the consequences of identifying a personal data breach resulting in a high risk of infringement of the rights or freedoms of individuals (and this

knowledge can be required not only from the Controller but also from the data protection officer appointed by them). Being aware of this, the Controller nevertheless decided not to fulfill their obligations specified in Article 33(1) and Articles 34(1) and (2) of Regulation 2016/679.

3. Actions taken to minimize the damage suffered by the individuals whose data is concerned (Article 83(2)(c) of Regulation 2016/679). The Controller did not provide the individual, which the data concerns, the complete information regarding the breach of her personal data protection deprived her of knowledge about the actual level of risk, which takes away her ability to independently assess the consequences of the breach of her data protection, and consequently hindered her from taking appropriate actions aimed at preventing the effects of this breach. It should be pointed out again that health data constitutes a special category of personal data and as such should be subject to special protection, and therefore the consequences of breaching the protection of this category of data can be particularly severe. Although it is commendable that the Administrator decided to notify the data subject about the breach of her personal data protection, he did not provide her with complete information regarding the security measures that she could independently take to prevent the use of her personal data in the form of health data.

4. Categories of personal data affected by the breach (Article 83(2)(g) of Regulation 2016/679). The personal data contained in the Anesthesia Questionnaire of the patient, which was improperly issued to an unauthorized person, which concerns the breach of the provisions of Regulation 2016/679, includes data regarding the first name, last name, PESEL identification number, and health data. The nature of the activities carried out by the Administrator requires him to process personal data subject to special protection under Article 9(1) of Regulation 2016/679. It should also be noted that the Anesthesia Questionnaire contains the PESEL number, which is an eleven-digit numerical symbol that uniquely identifies a natural person, containing the date of birth, serial number, gender designation, and control number, and thus is closely linked to the private sphere of the individual and is also subject, as a national identification number, to exceptional protection under Article 87 of Regulation 2016/679, being data of a special nature and requiring such special protection. There is no other, such specific data that would unequivocally identify a natural person. It is not without reason that the PESEL number serves as identifying data for every individual and is widely used in dealings with various institutions and in legal circulation. The PESEL number, along with the first name and last name, unequivocally identifies a natural person, allowing negative consequences of the breach (e.g., identity theft, loan fraud) to be attributed to that specific individual.

In this context, it is worth recalling the EROD 04/2022 guidelines, which state: "Regarding the requirement to consider the categories of personal data affected by the breach (Article 83(2)(g) of Regulation 2016/679), the types of data that are subject to special protection are clearly indicated in [Regulation 2016/679], and thus a more rigorous response is required when imposing financial penalties. This applies at least to the types of data covered by Articles 9 and 10 of [Regulation 2016/679] and to data not covered by the scope of these articles, the dissemination of which immediately causes harm or discomfort to the data subject (e.g., location data, private communication data, national identification numbers, or financial data such as transaction statements or credit card numbers). Generally speaking, the more categories of such data are affected by the breach or the more sensitive the data, the greater weight the supervisory authority may assign to such a factor. The amount of data concerning each individual whose data is affected also matters, as the scale of the breach of the right to privacy and personal data protection increases."

It is also worth pointing out the developing case law in this area, where, for example, in the judgment of November 15, 2022, case file II SA/Wa 546/22, the Provincial Administrative Court in Warsaw stated: "It was also obvious that the authority, when determining the amount of the penalty, had to take into account the fact that the breach concerned data of great sensitivity (including PESEL, address, health status data)." This view was also shared by the aforementioned Court in the judgment of June 21, 2023, in case file II SA/Wa 150/23, where the WSA in Warsaw stated: "In summary, the Court holds that the disclosure of the PESEL number indicates a high risk of violation of the rights or freedoms of natural persons."

In deciding to impose an administrative monetary penalty, the President of UODO took into account the following circumstances of the case, which necessitate the application of this type of sanction in this case and which have a mitigating effect on the amount of the imposed administrative monetary penalty:

1. The degree of cooperation with the supervisory authority in order to remedy the breach and mitigate its potential negative effects (Article 83(2)(f) of Regulation 2016/679). The Administrator reported the breach of personal data protection as a result of the initiation of administrative proceedings by the President of UODO in this case, and although this report constituted a specific response to the supervisory authority's inquiry, it represents an appropriate reaction to the letters directed to the Hospital, and therefore this circumstance should be classified as mitigating. At the same time, the President of UODO acknowledges the actions taken by the Administrator aimed at informing the data subject about the breach of her personal data protection, and although the notification directed to the individual does not provide her with all the information required by the provisions of Regulation 2016/679 (i.e., a description of the measures taken or proposed by the administrator to remedy the breach of personal data protection, including measures to minimize its potential negative effects concerning the category of personal data in the form of health data), it is considered a mitigating circumstance.

the Hospital's actions in this regard should be accepted.

Other circumstances indicated below, referred to in Article 83(2) of Regulation 2016/679, after assessing their impact on the identified violation in this case, have been deemed neutral by the President of the UODO, meaning they have neither an aggravating nor a mitigating effect on the amount of the imposed administrative monetary penalty.

1. The degree of responsibility of the controller, taking into account the technical and organizational measures implemented by it pursuant to Articles 25 and 32 (Article 83(2)(d) of Regulation 2016/679). Due to the nature of the violation of the provisions of Regulation 2016/679 identified in this case (failure to notify the President of the UODO of the personal data breach without undue delay, no later than 72 hours after its discovery) and the lack of proper notification to the data subject, due to the failure to provide all the information required under Article 34(2) of Regulation 2016/679 (not indicating a description of the measures taken or proposed by the controller to remedy the breach – including, where appropriate, measures to minimize its negative effects, taking into account all categories of personal data breached, i.e., health data) – which violations in their essence are not related to the technical and organizational measures applied by the controller – it should be accepted that the condition indicated in Article 83(2)(d) of Regulation 2016/679 has no aggravating or mitigating effect on the amount of the imposed administrative monetary penalty. It has no significance in assessing the Hospital's violation of the provisions of Articles 33(1) and Articles 34(1) and (2) of Regulation 2016/679.

2. Any relevant previous violations by the controller or processor (Article 83(2)(e) of Regulation 2016/679). The President of the UODO did not find any relevant previous violations of Regulation 2016/679 by X., therefore there are no grounds for treating this circumstance as aggravating; however, it is the duty of every controller to comply with the law (including provisions concerning personal data protection), which means that the absence of previous similar violations of personal data protection cannot be considered a mitigating circumstance when imposing sanctions.

3. The manner in which the supervisory authority became aware of the violation (Article 83(2)(h) of Regulation 2016/679). The President of the UODO was informed of the violation of Articles 33(1) and Articles 34(1) and (2) of Regulation 2016/679 related to the issuance of the Anesthesiology Survey Card of another patient to an unauthorized person by (...), which provided information obtained from a third party with access to that data. The failure to report the personal data breach to the supervisory authority within 72 hours of its discovery and the lack of immediate notification to the data subject, and the provision of a description of the measures taken or proposed by the controller to remedy the personal data breach, including measures to minimize its potential negative effects, is, however, the subject of this proceeding, and in the circumstances of the considered factual state, the supervisory

authority accepted that it would not treat this condition as an aggravating circumstance.

4. Compliance with previously applied measures in the same case referred to in Article 58(2) of Regulation 2016/679 (Article 83(2)(i) of Regulation 2016/679). Prior to issuing this decision, the President of the UODO did not apply any measures listed in Article 58(2) of Regulation 2016/679 against the controller in the case at hand, which means that the controller had no obligation to take any actions related to their application, and such actions, assessed by the President of the UODO, could have an aggravating or mitigating effect on the assessment of the identified violation.

5. The application of approved codes of conduct under Article 40 of Regulation 2016/679 or approved certification mechanisms under Article 42 of Regulation 2016/679 (Article 83(2)(j) of Regulation 2016/679). The Hospital did not inform whether it applies approved codes of conduct or approved certification mechanisms referred to in the provisions of Regulation 2016/679. Their adoption, implementation, and application are not, however, as stipulated by the provisions of Regulation 2016/679, mandatory for controllers and processors, which means that the circumstance of their non-application cannot be considered against the Administrator in this case. On the other hand, the circumstance of adopting and applying such instruments as measures guaranteeing a higher than standard level of protection for processed personal data could be taken into account in favor of the Administrator.

6. Financial benefits directly or indirectly achieved in connection with the violation or losses avoided (Article 83(2)(k) of Regulation 2016/679). The President of the UODO did not find that the controller had achieved any financial benefits or avoided such losses in connection with the violation. Therefore, there are no grounds for treating this circumstance as aggravating for the controller. The establishment of measurable financial benefits resulting from the violation of the provisions of Regulation 2016/679 should be assessed decidedly negatively. On the other hand, the failure of the controller to achieve such benefits, as a natural state independent of the violation and its effects, is a circumstance that, by its very nature, cannot be mitigating for the Administrator. This is confirmed by the very wording of Article 83(2)(k).

Regulation 2016/679, which requires the supervisory authority to pay due attention to the benefits "achieved" – that occurred on the part of the entity committing the violation.

7. Other aggravating or mitigating factors (Article 83(2)(k) of Regulation 2016/679). The President of the UODO, comprehensively considering the case, did not note any circumstances other than those described above that could affect the assessment of the violation and the amount of the imposed administrative monetary penalty.

Finally, it is necessary to indicate that in determining the amount of the administrative monetary penalty in this case, the President of the UODO applied the methodology adopted by the EROD in Guidelines 04/2022. According to the guidelines presented in this document:

1. The President of the UODO categorized the violation of the provisions of Regulation 2016/679 identified in this case (see Chapter 4.1 of Guidelines 04/2022). The violation of Article 33(1) and Article 34(1) and (2) of Regulation 2016/679 identified in this case falls – in accordance with Article 83(4)(a) of Regulation 2016/679 – into the category of violations subject to a lower penalty of the two provided for in Regulation 2016/679 (with a maximum amount of up to EUR 10,000,000 or up to 2% of the total annual turnover of the enterprise from the previous financial year). Thus, it has been considered in abstracto (irrespective of the individual circumstances of the specific case) by the EU legislator as less serious than the violations indicated in Article 83(5) of Regulation 2016/679.

2. The President of the UODO assessed the violation identified in this case as a violation of low severity (see Chapter 4.2 of Guidelines 04/2022). In this assessment, the factors among those listed in Article 83(2) of Regulation 2016/679 that pertain to the subject matter of the violation (constituting the "seriousness" of the violation), namely: the nature, gravity, and duration of the violation (Article 83(2)(a) of Regulation 2016/679), the intentional or unintentional nature of the violation (Article 83(2)(b) of Regulation 2016/679), and the categories of personal data affected by the violation (Article 83(2)(g) of Regulation 2016/679) were taken into account. A detailed assessment of these circumstances has

been presented above. It should be noted here that considering their cumulative impact on the assessment of the violation identified in this case treated in its entirety leads to the conclusion that the level of its severity is also low in concreto (on the scale of severity of violations presented in point 60 of Guidelines 04/2022). As a consequence, the starting amount for calculating the penalty was set within the range of 0 to 10% of the maximum penalty that could be imposed on the Hospital. Given that Article 83(4) of Regulation 2016/679 obliges the President of the UODO to adopt, as the maximum amount for violations indicated in this provision, the amount of EUR 10,000,000 or – if this amount is higher than EUR 10,000,000 – the amount representing 2% of the turnover from the previous financial year, the President of the UODO states that the so-called static maximum penalty amount of EUR 10,000,000 applies in this case. The application of the 2% rate applied to the Hospital's turnover for the financial year ending December 31, 2023 (... EUR, which is equivalent to (...) PLN according to the average EUR exchange rate on January 29, 2024) results in the amount of (...) EUR - lower than the static maximum penalty mentioned in Article 83(4) of Regulation 2016/679. Having at his disposal a range from 0 to EUR 10,000,000, the President of the UODO accepted, as adequate and justified by the circumstances of the case, the starting amount for calculating the penalty to be EUR 200,000 (representing 2% of the static maximum penalty).

3. The President of the UODO adjusted the starting amount corresponding to the low severity of the identified violation to the Hospital's turnover as a measure of its size and economic strength (see Chapter 4.3 of Guidelines 04/2022). According to Guidelines 04/2022, in the case of enterprises with an annual turnover between EUR 10 million and EUR 50 million, the supervisory authority may consider making further calculations of the penalty amount based on a value ranging from 1.5% to 10% of the starting amount. Given that the Hospital's turnover in the last reporting year (ending December 31, 2023) amounted to (...) PLN, which is (...) EUR (according to the average EUR exchange rate on January 29, 2024), the President of the UODO deemed it appropriate to adjust the amount subject to calculations to a value corresponding to 4% of the starting amount, i.e., to the amount of EUR 8,000 (equivalent to 34,922.40 PLN).

4. The President of the UODO assessed the impact on the identified violation of other circumstances (besides those considered above in the assessment of the severity of the violation) indicated in Article 83(2) of Regulation 2016/679 (see Chapter 5 of Guidelines 04/2022). These circumstances, which may have an aggravating or mitigating impact on the assessment of the violation, relate – as assumed by Guidelines 04/2022 – to its subjective side, that is, to the entity itself that is the perpetrator of the violation of the provisions of Regulation 2016/679 and to its behavior before, during, and after the occurrence of the violation. A detailed assessment and justification of the impact of each of these factors on the assessment of the violation have been presented above. The President of the UODO considered that the mitigating circumstances in this case are the degree of cooperation of the Hospital with the supervisory authority in order to remedy the violation and mitigate its negative effects (Article 83(2)(f) of Regulation 2016/679). Conversely, the actions taken by the Hospital to minimize the damage suffered by the data subject (Article 83(2)(c) of Regulation 2016/679) have an aggravating effect on the penalty. The remaining factors (from Article 83(2)(d), (e), (h), (i), (j), and (k) of Regulation 2016/679) – as indicated above – had no mitigating or aggravating impact on the assessment of the violation of the provisions of Regulation 2016/679 and consequently on...

****Penalty Assessment.**** Due to the presence of the above mitigating and aggravating circumstances in the case, the President of the UODO (Personal Data Protection Office) deemed it appropriate to reduce the amount of the penalty established above; in the opinion of the President of the UODO, the appropriate reduction in the amount, considering the overall impact of the aforementioned circumstances on the assessment of the violation, is to 6800 EUR (equivalent to 29,684.04 PLN).

5. The President of the UODO determined that the amount of the aforementioned penalty does not require further adjustment due to the principle of proportionality mentioned in Article 83(1) of Regulation 2016/679, which is one of the three directives for penalty assessment (see Chapter 7 of Guidelines 04/2022). The monetary penalty of 6800 EUR will be effective (due to its severity, it will achieve its repressive goal of punishing unlawful behavior) and deterrent (effectively discouraging both

the Hospital and other administrators from committing violations of the provisions of Regulation 2016/679 in the future). The principle of proportionality requires, among other things, that the measures adopted by the supervisory authority do not exceed what is appropriate and necessary to achieve legitimate objectives (see points 137 and 139 of Guidelines 04/2022). In other words: "A sanction is proportional if it does not exceed the threshold of severity determined by taking into account the circumstances of the specific case" (P. Litwiński (ed.), Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016 [...]; Commentary on Article 83 [in:] P. Litwiński (ed.) General Data Protection Regulation. Data Protection Act. Selected sectoral provisions. Commentary). The amount of 6800 EUR (equivalent to 29,684.04 PLN) constitutes a threshold above which further increases in the penalty amount will not be associated with an increase in its effectiveness and deterrent nature. On the other hand, a greater reduction in the penalty amount could occur at the expense of its effectiveness and deterrent nature, as well as the consistent application and enforcement of Regulation 2016/679 and the principle of equal treatment of entities in the EU and EEA internal market.

In the opinion of the President of the UODO, the administrative monetary penalty applied meets, in the established circumstances of this case, the functions referred to in Article 83(1) of Regulation 2016/679, i.e., it is effective, proportional, and deterrent in this individual case. It should be emphasized that the penalty will be effective if its imposition leads to the Hospital fulfilling its obligations regarding personal data protection in the future, particularly in terms of reporting personal data breaches to the President of the UODO.

In the opinion of the President of the UODO, the administrative monetary penalty will also serve a repressive function, as it will be a response to the Hospital's violation of the provisions of Regulation 2016/679. It will also fulfill a preventive function. In the opinion of the President of the UODO, it will indicate to both the Hospital and other administrators the reprehensibility of neglecting the obligations of administrators related to the occurrence of personal data breaches, which aim to prevent their negative and often severe consequences for the individuals affected by the breach, as well as to eliminate those consequences or at least mitigate them.

Pursuant to Article 103 of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781), hereinafter referred to as "uodo", the equivalent of the amounts expressed in euros referred to in Article 83 of Regulation 2016/679 is calculated in zlotys according to the average euro exchange rate announced by the National Bank of Poland in the exchange rate table on January 28 of each year, and in the event that the National Bank of Poland does not announce the average euro exchange rate on January 28 of a given year – according to the average euro exchange rate announced in the nearest exchange rate table of the National Bank of Poland after that date.

In light of the above, the President of the UODO, based on Article 83(4)(a) in conjunction with Article 103 of the uodo, for the violation described in the operative part of this decision, imposed on the Hospital – using the average euro exchange rate from January 29, 2024 (1 EUR = 4.3653 PLN) – an administrative monetary penalty in the amount of 29,684.04 PLN (which is equivalent to 6800 EUR).

In the opinion of the President of the UODO, the monetary penalty of 29,684.04 PLN (in words: twenty-nine thousand six hundred eighty-four zlotys and four groszy) meets, in the established circumstances of this case, the criteria referred to in Article 83(1) of Regulation 2016/679 due to the seriousness of the established violation in the context of the primary objective of Regulation 2016/679 – the protection of the fundamental rights and freedoms of individuals, particularly the right to personal data protection.

Regarding the amount of the administrative monetary penalty imposed on the Hospital, the President of the UODO found that it is proportional to the financial situation of the Administrator and will not constitute an excessive burden for it.

From the financial report presented by the Administrator, it follows that the total revenues of the Hospital for the financial year ending December 31, 2023, amounted to (...) PLN, which means that the amount of the administrative monetary penalty imposed in this case constitutes approximately

(...)% of the aforementioned revenue amount. At the same time, it is worth noting that the amount of the imposed penalty of 29,684.04 PLN is only 0.07% of the maximum penalty that the President of the UODO could – in accordance with Article 83(4) of Regulation 2016/679, applying the static maximum penalty (i.e., 10,000,000 euros) – impose on the Hospital for the violation of the provisions of Regulation 2016/679 established in this case.

The amount of the penalty has been set at such a level that, on the one hand, it constitutes an adequate response from the supervisory authority to the degree of violation of the administrator's obligations, while on the other hand, it does not create a situation in which the necessity to pay the financial penalty would lead to negative consequences, in the form of a significant reduction... employment or significant decline in the Hospital's turnover. According to the President of the Personal Data Protection Office (UODO), the Hospital should and is capable of bearing the consequences of its negligence in the area of data protection, as evidenced by the Hospital's financial report submitted to the President of UODO on April 8, 2024. Furthermore, the supervisory authority, when determining the amount of the fine, took into account the financial situation of the Administrator as of the date of issuance of this administrative decision, i.e., the fact that from (...) to the present, there is an ongoing (...). In this factual and legal context, the President of the Personal Data Protection Office ruled as stated in the operative part.

[1] The aforementioned Guidelines updated and supplemented the Guidelines of the Article 29 Working Party regarding the reporting of personal data breaches in accordance with Regulation 2016/679 (Wp250 rev.01), adopted on October 3, 2017.

[2] https://edpb.europa.eu/system/files/2024-01/edpb_guidelines_042022_calculationofadministrativefines_pl

Print article

Metadata

Provider:

Department of Control and Violations

Created by:

Mirosław Wróblewski

2024-11-26

Entered by:

Wioletta Golańska

2024-12-16 12:38:15

Last modified by:

Karolina Jastalska

2024-12-16 14:58:08